ĐẶC TẢ YÊU CẦU PHẦN MỀM — SHILOSKIN

Nguyễn Từ Lân – 23110306 · 25/10/2026 · ShiloSkin v1.0

0. Kiểm soát, mục đích và mức chuẩn tắc

SRS 1.0, chủ hệ thống Nguyễn Từ Lân – 23110306, tham chiếu URD 1.0 và API 1.0 cùng bộ. Đây là baseline hành vi ĐÚNG để thiết kế testcase, có thể review và ký nhận; chưa có chữ ký phê duyệt. Bản thực hành có thể cố ý chứa sai lệch để học kiểm thử; không dùng sai lệch hiện tại làm expected result. Danh mục lỗi bố trí riêng không nằm trong bộ bàn giao công khai này.

1. Kiến trúc và môi trường

Một web app Flask/SQLite, HTML/CSS/JavaScript, API JSON cùng domain. Server triển khai bằng WSGI/Gunicorn sau Nginx/HTTPS của lab; môi trường cục bộ dùng Python 3.11+ với server thử nghiệm. Phiên cookie ký số, mật khẩu hash scrypt, CSRF trên API ghi dữ liệu.

Không kết nối Steam, không thanh toán hoặc giao dịch tài sản thật. SC là credit mô phỏng nguyên. Giá tham khảo của skin là metadata bài tập, không phải khuyến nghị mua bán hay dữ liệu thị trường.

2. Thuật ngữ và dữ liệu

Skin/model là catalog metadata; inventory item là bản ghi vật phẩm có một owner. Listing là tin đăng bán item; trade là đề nghị đổi hai item. Proposer gửi đề nghị, recipient là owner của item được muốn đổi tại thời điểm tạo.

Entity · Thuộc tính nghiệp vụ · Ràng buộc chính

User · id, username, name, password_hash, role, active, balance, session_version · 3 role; balance nguyên SC; không trả password_hash

Skin · id, name, weapon, rarity, wear, float_value, reference_price, active, timestamps · Name/weapon 1..120; float hữu hạn 0..1; price 1..100000

Inventory · id, skin_id, owner_id, acquired_at · Một owner; locked được tính từ tin ACTIVE

Listing · id, item_id, seller_id, buyer_id, price, status, moderation_reason, timestamps · Tối đa một ACTIVE/item; SOLD chỉ một buyer

Trade · id, proposer_id, recipient_id, give_item_id, want_item_id, status, timestamps · 1:1, không tự đổi, không lặp cặp PENDING

History · actor_id, other_id, action, entity_type/id, detail, created_at · Chỉ các bên liên quan đọc; bất biến

Notification · recipient_id, event_type, body, entity_type/id, is_read, created_at · Chỉ người nhận; is_read bền vững

Idempotency · user, method, path, key, digest, response/status · Cùng thao tác retry không chạy lại tác động

Rarity: Consumer Grade, Industrial Grade, Mil-Spec, Restricted, Classified, Covert. Wear: Factory New, Minimal Wear, Field-Tested, Well-Worn, Battle-Scarred. Đây là enum khai báo của demo; app không tự suy wear từ float hoặc xác minh metadata với nhà phát hành.

Timestamps API dùng ISO8601 UTC. Name/weapon/reason/username được trim; mật khẩu được kiểm không trống nhưng không trim trước so hash. Query casefold, không tự bỏ dấu. Trường boolean phải là boolean JSON; ID nguyên dương, boolean không được coi là số.

3. Yêu cầu chức năng

FR-01 — Đăng nhập, phiên và đăng xuất

Actor: MEMBER / MODERATOR / ADMIN. Truy vết: US-01.

Tài khoản 1–80 ký tự sau trim; mật khẩu 1–200 ký tự, không chỉ khoảng trắng, giữ nguyên ký tự khi so hash. Tài khoản hoạt động và thông tin đúng được đăng nhập 200; sai, khóa hoặc không tồn tại dùng cùng lỗi 401. /me trả hồ sơ, vai trò, số dư và CSRF. Phiên tối đa 8 giờ; đăng xuất thu hồi phiên, cookie cũ bị 401.

FR-02 — Danh mục skin và bộ lọc

Actor: Cả ba vai trò. Truy vết: US-02.

GET /skins liệt kê 12 mẫu ban đầu; tìm chuỗi con theo tên HOẶC weapon bằng Unicode casefold; q tối đa 200 ký tự. Có bộ lọc weapon, rarity và wear. MEMBER/MODERATOR chỉ thấy mẫu active; ADMIN thấy cả mẫu ngừng hoạt động. rarity/wear ngoài enum trả 400; kết hợp bộ lọc theo AND.

FR-03 — Kiểm tra chi tiết skin

Actor: Cả ba vai trò. Truy vết: US-02.

Chi tiết theo ID hiển thị tên, loại súng trong trò chơi, độ hiếm, tình trạng, float, giá tham khảo bằng SC và trạng thái catalog. ID không tồn tại trả 404. Float là metadata demo do admin khai báo, không xác minh vật phẩm Steam hoặc giá thị trường thực. Mẫu ngừng hoạt động vẫn có thể xem chi tiết để giữ tham chiếu.

FR-04 — Kho vật phẩm và kiểm tra đối tác

Actor: Cả ba vai trò đọc; MEMBER giao dịch. Truy vết: US-03.

Kho mặc định của tài khoản; MEMBER có 4 vật phẩm ban đầu. Cho đọc metadata kho MEMBER khác qua user_id để chọn vật phẩm muốn đổi; đây là dữ liệu công khai của demo. Không lộ mật khẩu/khóa phiên. locked=true khi vật phẩm có tin ACTIVE. user_id không hợp lệ 400; MEMBER truy vấn người không phải MEMBER hoặc ID không tồn tại trả 404.

FR-05 — Tạo tin đăng bán

Actor: MEMBER. Truy vết: US-04.

Chỉ đăng vật phẩm đang thuộc mình, không có tin ACTIVE và mẫu còn active. item_id là số nguyên dương. Giá là số nguyên 1..100000 SC, không nhận boolean, số thập phân hoặc chuỗi không nguyên. Vật phẩm người khác 403; đã có tin ACTIVE 409; thành công 201, ACTIVE, có lịch sử và thông báo của người bán.

FR-06 — Hủy tin của mình

Actor: MEMBER người bán. Truy vết: US-04.

Chỉ người bán của tin ACTIVE được hủy, chuyển CANCELLED và mở khóa vật phẩm. Người khác 403; SOLD/HIDDEN/CANCELLED hoặc hủy lặp trả 409. Hủy không chuyển quyền sở hữu và không trả lại xu của giao dịch đã hoàn tất.

FR-07 — Mua bằng xu mô phỏng

Actor: MEMBER người mua. Truy vết: US-05.

Tin phải ACTIVE, người mua khác người bán và đủ SC. Chủ sở hữu item còn là seller hợp lệ, active và role MEMBER. Chỉ một người mua thành công: chuyển item, trừ người mua/cộng người bán đúng price và chuyển SOLD trong một giao dịch. Không tự mua hoặc thiếu xu: 409, không đổi dữ liệu. Ghi BUY và thông báo hai bên. Tin đã được đăng hợp lệ vẫn có thể bán khi mẫu catalog bị ẩn sau đó; catalog ngừng hoạt động chặn đăng mới, không thu hồi tin cũ trong MVP.

FR-08 — Gửi đề nghị đổi 1:1

Actor: MEMBER người đề nghị. Truy vết: US-06.

give_item_id thuộc mình; want_item_id thuộc MEMBER khác đang active. Hai ID khác nhau, hai item không nằm trong tin ACTIVE, hai mẫu catalog còn active. Thành công 201, PENDING, ghi lịch sử và thông báo người nhận. Tự đổi 400; cho item không thuộc mình 403; item bị khóa hoặc trùng cặp đề nghị PENDING 409. Đề nghị PENDING không giữ chỗ vật phẩm.

FR-09 — Chấp nhận và hoán đổi

Actor: MEMBER người nhận. Truy vết: US-06.

Chỉ recipient của PENDING được accept. Kiểm tra lại chủ của hai item, hai item chưa đăng bán, mẫu còn active và proposer còn active/role MEMBER. Sau đó hoán đổi owner atomically và chuyển ACCEPTED; không trao đổi SC. REJECTED/CANCELLED/ACCEPTED không thể accept lại: 409. Người không phải recipient: 403.

FR-10 — Từ chối hoặc rút đề nghị

Actor: MEMBER liên quan. Truy vết: US-06.

Recipient được reject PENDING → REJECTED; proposer được cancel PENDING → CANCELLED. Không đổi owner hay SC. Sai bên thao tác 403; xử lý lại trạng thái kết thúc 409. Có lịch sử và thông báo đối tác. Không có chức năng sửa hoặc mở lại đề nghị đã kết thúc.

FR-11 — Lịch sử hoạt động

Actor: Cả ba vai trò. Truy vết: US-07.

Người dùng chỉ đọc event mình là actor hoặc other_id; không phải nhật ký công khai toàn hệ thống. Có action, entity_type, entity_id, detail, actor và thời gian UTC. BUY, CREATE_LISTING, CANCEL_LISTING, CREATE_TRADE, TRADE_ACCEPTED/REJECTED/CANCELLED, MODERATE, CREATE_SKIN, UPDATE_SKIN, UPDATE_USER được ghi. Không cung cấp API sửa/xóa lịch sử.

FR-12 — Hồ sơ và số dư

Actor: Cả ba vai trò. Truy vết: US-01 / US-05.

GET /me trả id, username, name, role, balance nguyên. Balance là SC mô phỏng, không nạp/rút tiền; MEMBER01 ban đầu 1000, MEMBER02 1500, MODERATOR/ADMIN 0. Sau mua phải phản ánh số dư mới. Giao dịch chuẩn không tạo số dư âm; tổng SC hai bên được bảo toàn. Không có API sửa số dư tự do.

FR-13 — Kiểm duyệt ẩn tin

Actor: MODERATOR. Truy vết: US-08.

Chỉ MODERATOR được ẩn tin ACTIVE; reason 1..1000 ký tự sau trim bắt buộc. Chuyển HIDDEN, mở khóa vật phẩm, ghi MODERATE và báo người bán kèm lý do. Thiếu lý do 400; sai vai trò 403; tin không ACTIVE 409. MVP chưa có khôi phục HIDDEN; người bán có thể tạo tin mới nếu đáp ứng FR-05.

FR-14 — Quản trị tài khoản

Actor: ADMIN. Truy vết: US-09.

GET /users không trả hash; PATCH sửa name 1..120, role MEMBER/MODERATOR/ADMIN, active boolean. Không được tự khóa hoặc tự bỏ ADMIN. MEMBER còn tin ACTIVE hoặc đề nghị PENDING không được đổi sang role khác: 409. Khóa/đổi hồ sơ thu hồi phiên trước đó. Bản MVP cấp sẵn 4 tài khoản, chưa có đăng ký/tạo hoặc tự khôi phục mật khẩu.

FR-15 — Quản trị metadata skin

Actor: ADMIN. Truy vết: US-09.

Tạo/sửa tên và weapon 1..120 sau trim; rarity/wear thuộc enum; float_value hữu hạn trong [0,1]; reference_price nguyên 1..100000 SC, mặc định 100 khi tạo nếu bỏ qua; active boolean mặc định true. Tạo trả 201/id; sửa trả 200. Không xóa model có tham chiếu. Thay metadata không tự cấp thêm inventory.

FR-16 — Thông báo và đã đọc

Actor: Cả ba vai trò. Truy vết: US-07.

Chỉ đọc thông báo recipient_id hiện tại; có event, body, entity, thời điểm và is_read. POST /read chỉ của mình; sau tải lại is_read vẫn 1. ID người khác/không tồn tại 404. Tạo tin, mua/bán, đề nghị/xử lý đổi và kiểm duyệt phát thông báo sau nghiệp vụ thành công trong cùng transaction.

4. Ma trận quyền API

Nhóm thao tác · MEMBER · MODERATOR · ADMIN

Login/logout/me, catalog/chi tiết · Có · Có · Có

Xem metadata kho MEMBER · Có · Có · Có

Đọc danh sách tin · Có · Có · Có

Đăng/hủy tin · Item/tin của mình, đúng state · Không · Không

Mua tin · Tin người khác, đúng state và đủ SC · Không · Không

Gửi/xem đề nghị đổi · Chỉ các đề nghị liên quan · Không · Không

Accept/reject · Đúng recipient PENDING · Không · Không

Cancel đề nghị · Đúng proposer PENDING · Không · Không

Ẩn tin · Không · ACTIVE + lý do · Không

Danh sách/sửa tài khoản · Không · Không · Có, có bảo vệ self/role change

Tạo/sửa catalog · Không · Không · Có

History/notification · Chỉ liên quan/chỉ của mình · Chỉ liên quan/chỉ của mình · Chỉ liên quan/chỉ của mình

Mọi ghi dữ liệu sau login yêu cầu phiên hợp lệ và X-CSRF-Token trước khi chạy nghiệp vụ. UI ẩn nút không thay phân quyền server. Tài khoản inactive hoặc session_version đổi bị thu hồi phiên. Đăng xuất chủ ý thu hồi mọi cookie phiên của tài khoản đó trong MVP.

5. Vòng đời và chuyển trạng thái

5.1. Tin đăng

ACTIVE -- seller cancel --> CANCELLED

ACTIVE -- other member buys atomically --> SOLD

ACTIVE -- moderator reason --> HIDDEN

SOLD, CANCELLED và HIDDEN là trạng thái kết thúc của tin. Chủ item có thể đăng một tin mới nếu không còn ACTIVE; tin cũ không được mở lại. Sau SOLD owner item là buyer; seller cũ không được tác động item chỉ vì vẫn là seller của hồ sơ tin cũ.

5.2. Đề nghị đổi

PENDING -- recipient accepts + recheck both items --> ACCEPTED

PENDING -- recipient rejects --> REJECTED

PENDING -- proposer cancels --> CANCELLED

Không có cạnh từ trạng thái kết thúc về PENDING/ACCEPTED. PENDING không khóa item; vì vậy thay owner hoặc đăng item vào ACTIVE trước thời điểm accept làm accept thất bại 409 và giữ đề nghị chờ để các bên từ chối/hủy.

6. Bảng quyết định

6.1. Quyết định mua

Điều kiện · Trường hợp A · B · C · D · E

Vai trò MEMBER · Không · Có · Có · Có · Có

Tin ACTIVE/chủ hợp lệ · — · Không · Có · Có · Có

Buyer khác seller · — · — · Không · Có · Có

Đủ số dư · — · — · — · Không · Có

Kết quả · 403 · 409 · 409 · 409 · 200 + một transfer/SOLD

6.2. Quyết định chấp nhận đổi

Điều kiện · K1 · K2 · K3 · K4

Đúng recipient MEMBER · Không · Có · Có · Có

State PENDING · — · Không · Có · Có

Hai item/owner/active/khóa còn hợp lệ · — · — · Không · Có

Kết quả · 403 · 409 · 409, không swap · 200 + swap/ACCEPTED

7. Validation và lỗi

Input sai kiểu, trống, ngoài khoảng hoặc action không thuộc enum →400; chưa đăng nhập/hết phiên/khóa →401; sai quyền hoặc CSRF →403; entity thiếu →404; trùng/chuyển state xung đột →409; body quá lớn →413. Response lỗi JSON có trường error, không xuất traceback/mật khẩu. HTTP500 là lỗi hệ thống, không được dùng thay validation/not-found trong các NFR đã định.

Nếu transaction lỗi, rollback mọi thay đổi của thao tác đó. Không trả success khi chưa commit; không tự hoàn tiền hoặc đảo item sau khi một giao dịch đã được xác nhận hoàn tất bằng API khác.

8. Yêu cầu phi chức năng và cách đo

ID · Tên · Ngưỡng/tiêu chí · Phương pháp

NFR-01 · Hiệu năng tìm skin · GET /api/skins?q=...: p95 ≤800 ms, error <1%, tải thường 2 người dùng, ramp-up 10 giây, chạy 300 giây. Thử 1 người dùng dùng làm kiểm tra sơ bộ, không thay tải thường. · JMeter/HTTP, nhận hết response body; không cộng thời gian định thời tải.

NFR-02 · Hiệu năng thông báo · GET /api/notifications: p95 ≤900 ms, error <1%, 2 người dùng trong 300 giây, ramp-up 10 giây. · JMeter/HTTP cùng kế hoạch tải thường; báo riêng login và business requests.

NFR-03 · Hiệu năng duyệt danh mục/tin · GET /api/listings và GET /api/skins không q: p95 ≤1000 ms, error <1%, tăng bậc 1→2→4 người dùng; 120 giây/bậc, ramp-up 5 giây, timer nhóm giới hạn mục tiêu 3 request/giây. · JMeter non-GUI, JTL + native dashboard; chưa suy rộng quá 4 người dùng.

NFR-04 · Bố cục có thể sử dụng · 375×812, 768×1024, 1366×768: hộp thoại nằm trong viewport, nhãn trạng thái và độ hiếm nhìn thấy; tên hợp lệ có khoảng cách không cắt im lặng trên desktop. Bảng có thể cuộn bên trong vùng riêng. · Ảnh DOM/bounding box; kiểm các luồng thị trường, kho, đề nghị.

NFR-05 · Nội dung nhất quán · ACCEPTED hiển thị Đã chấp nhận; tiền mô phỏng ghi SC, không ký hiệu USD; hướng dẫn float ghi 0..1. Nhãn phải khớp mã trạng thái API, không đổi thông điệp nghiệp vụ. · Đối chiếu từ điển, DOM và JSON theo cùng entity.

NFR-06 · Bảo mật tối thiểu · 0 lần nghiệp vụ thành công trong ≥6 phép thử thiếu phiên/sai role/sai owner/thiếu CSRF; HTTPS; cookie Secure, HttpOnly, SameSite=Lax. Không lộ password/hash/token trong API công khai và báo cáo. · API âm, cookie live HTTPS, kiểm quyền từng thao tác.

NFR-07 · Nhất quán và retry · Mua/đổi cùng item đồng thời: tối đa 1 lần thành công; tổng SC bảo toàn khi mua; hoán đổi 2 owner trong một transaction. Retry cùng key/body trả kết quả cũ, không lặp chuyển SC/item/thông báo; khác body cùng key trả 409. · Concurrent client và đọc lại inventory/balance/listing/trade; Idempotency-Key.

NFR-08 · Chịu đầu vào không hợp lệ · GET /skins/ID không tồn tại →404; POST /listings với price='abc' →400, không trả 500. Sau lỗi /me và list vẫn 200; lỗi một request không dừng process. · API âm và bước kiểm tra phục hồi ngay sau lỗi.

NFR-09 · Giới hạn dữ liệu · Name/weapon 1..120 sau trim; float hữu hạn [0,1]; listing/reference price nguyên 1..100000; reason 1..1000; q ≤200; JSON request ≤1 MiB. Sai dữ liệu trả 400/413 và rollback, không ghi một phần. · EP/BVA: 0/1/max/max+1, khoảng trắng, boolean, số không hữu hạn/sai kiểu.

NFR-10 · Truy vết bất biến · 100% BUY/TRADE/MODERATE và thao tác quản trị có actor, entity, chi tiết, timestamp. Chỉ các bên liên quan đọc history; không API sửa/xóa history. Sai nghiệp vụ không tạo event thành công. · Đối chiếu event sau action và đọc route inventory; giữ raw evidence.

8.1. Fixture và giới hạn tải

Fixture khởi tạo mới: 12 skin model, 8 inventory item, 2 tin ACTIVE, 4 tài khoản (2 MEMBER + 1 MODERATOR + 1 ADMIN). member01 có item 1..4; member02 có item 5..8; tin #1 item5 giá400SC, tin #2 item6 giá2200SC. Kho đối tác item7/8 chưa đăng là dữ liệu đổi thử. Kết quả test phải dùng fixture riêng, không reset dữ liệu live chung.

Trước khi đo tải, ghi lại số model/item/tin sau các bước setup; tối đa 20 model cho kế hoạch này. Nếu có setup thêm catalog/item thì báo số thực, không giữ nhãn “12/8/2” khi dữ liệu đã đổi. Tải cục bộ cùng server/tool không đại diện năng lực VPS. Chỉ tải GET đã nêu, không vượt 4 người dùng hoặc giới hạn mục tiêu 3 request/s của step test. Chưa có phép ngoại suy bão hòa, stress không giới hạn hay đo trên hạ tầng dùng chung ngoài khung giờ cho phép.

9. Truy vết và thiết kế kiểm thử

Luồng · FR · NFR trọng yếu · Kỹ thuật cần phủ

FLOW-01 mua · 01..07, 11, 12, 16 · 06,07,09,10 · EP/BVA giá, bảng quyết định đủ SC/tự mua, state tin, retry/concurrency

FLOW-02 đổi · 01,03,04,08..12,16 · 06,07,09,10 · Owner × role × state, swap atomic, đối tác kết thúc, E2E

FLOW-03 kiểm duyệt · 01,02,03,11,13,16 · 04,05,06,09,10 · Reason BVA, role, ACTIVE/HIDDEN, thông báo

Quản trị · 14,15 · 06,08,09,10 · Tài khoản khóa, không tự khóa, float biên, enum, lỗi JSON

Hiệu năng/nội dung/UI · 02,03,04,07,09,16 · 01..05,08 · Đúng dataset/viewports, HTTP timing, ảnh cùng entity

10. Hạn chế và lựa chọn cần được review

Baseline dùng cấp sẵn tài khoản, không đăng ký hoặc thêm inventory từ Steam; 1 item/1 listing, đổi 1:1 không bù SC; giá tham khảo thủ công; không auto hủy các đề nghị PENDING khi item thay đổi; inactive catalog không tự thu hồi tin đang

bán; không có khôi phục tin HIDDEN. Những lựa chọn này là phạm vi MVP được khai báo, không tự gán thành lỗi ngoài đặc tả hoặc tính năng đã được yêu cầu trong đề gốc.

Các mục NFR là mục tiêu chuẩn tắc của bản yêu cầu, không phải báo cáo đã đạt. Tình trạng thực đo, lỗi và phần chưa chạy phải lấy từ báo cáo thực thi; bản này không mạo danh xác nhận của Bùi Xuân Minh – 23110193. AI hỗ trợ cả hai ứng dụng; cần khai báo cùng báo cáo và không khẳng định blind test.